HỌC VIỆN SÁNG TẠO KHỞI NGHIỆP TỪ CÔNG NGHỆ

BỘ 05 BÀI TẬP THỰC HÀNH NÂNG CAO – UBUNTU LINUX, MẠNG, VPN VÀ DOCKER

BÁO CÁO KỸ THUẬT

BÀI 3

PHÂN QUYỀN LINUX THEO VAI TRÒ VÀ KIỂM SOÁT TRUY CẬP THƯ MỤC

Sinh viên	Trần Đức Việt Anh
Server	maychucuavietanh – Ubuntu 24.04.1 LTS, kernel 6.8.0-139-generic (x86_64)
Thời gian	Triển khai 10–11/09/2026; kiểm thử 11/09/2026 (UTC+7)

Hà Nội, tháng 09 năm 2026

1. Thông tin bài thực hành

Hạng mục	Nội dung
Bài thực hành	Bài 3 – Phân quyền Linux theo vai trò và kiểm soát truy cập thư mục
Sinh viên	Trần Đức Việt Anh
Server	Hostname `maychucuavietanh`; Ubuntu 24.04.1 LTS; kernel 6.8.0-139-generic x86_64
Mạng	Interface `eth0`, IP công cộng 103.216.118.115; SSH lắng nghe cổng 24700
Thời gian triển khai	10/09/2026 23:54 – 11/09/2026 10:07 (theo mốc thời gian của cây thư mục `/srv/company`)
Thời gian kiểm thử	11/09/2026 từ 12:34 (UTC+7), đăng nhập SSH bằng từng tài khoản
Tình trạng hồ sơ	17/33 tiêu chí đạt, 5 không đạt, 11 chưa có minh chứng (xem `06_Checklist.txt`). Có 1 sự cố mức cao chưa có minh chứng khắc phục (S1).

2. Hiện trạng ban đầu và yêu cầu cần đạt

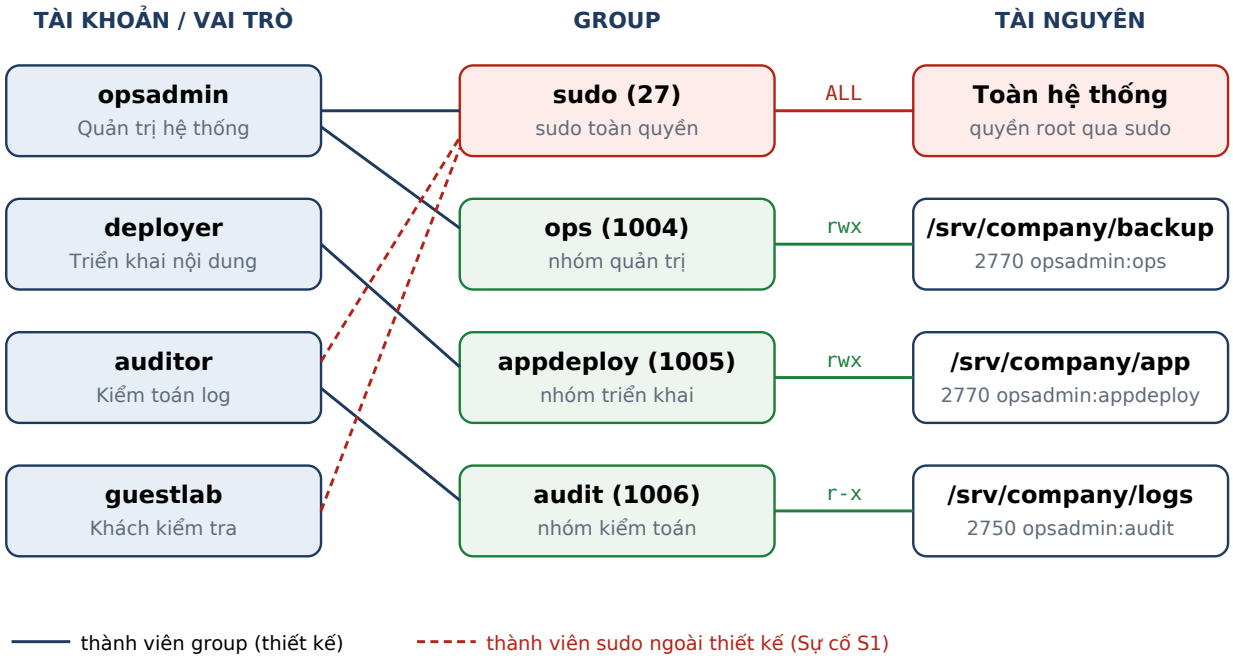
Trước khi thực hiện, dự án dùng chung một tài khoản có sudo cho cả ba nhóm nhân sự. Mô hình này có ba hệ quả: không xác định được ai đã thay đổi file, ai đã đọc log, và bất kỳ ai cũng có thể xóa dữ liệu. Bài thực hành thiết kế lại hệ thống tài khoản theo **nguyên tắc đặc quyền tối thiểu**. Mỗi người có tài khoản riêng, quyền được cấp qua group vai trò, quyền thư mục được khóa bằng permission POSIX kết hợp ACL, và quyền sudo chỉ cấp theo danh sách lệnh cụ thể.

Vai trò	Tài khoản	Yêu cầu
Quản trị hệ thống	`opsadmin`	Thực hiện tác vụ quản trị cần thiết; toàn quyền trên 3 thư mục nghiệp vụ.
Triển khai nội dung	`deployer`	Tạo, sửa, đổi tên file trong app; không sửa được log; không đọc được backup; sudo theo danh sách lệnh tối thiểu.
Kiểm toán	`auditor`	Chỉ đọc `logs`; không ghi, xóa, đổi tên hay đổi permission của log.
Khách kiểm tra	`guestlab`	Chỉ đăng nhập; nhận thông báo từ chối ở cả 3 thư mục nghiệp vụ.

3. Sơ đồ user – group – role và ma trận quyền

3.1. Sơ đồ phân quyền

Sơ đồ dưới đây thể hiện trạng thái thực tế ghi nhận tại MC-01. Đường nét liền là thiết kế: mỗi tài khoản vào đúng một group vai trò, mỗi group được cấp quyền trên đúng một thư mục. Đường nét đứt màu đỏ là hai thành viên group `sudo` nằm ngoài thiết kế, được phân tích ở Sự cố S1.



opsadmin là owner cả 3 thư mục (user::rwx). guestlab không thuộc group nghiệp vụ nào => rơi vào other::--- ở cả 3 thư mục.

Hình 1. Sơ đồ user – group – role (trạng thái tại MC-01)

3.2. Ma trận quyền theo thiết kế

Tài khoản	/srv/company/app	/srv/company/logs	/srv/company/backup
`opsadmin`	rwx – owner	rwx – owner	rwx – owner
`deployer`	rwx – qua group appdeploy	--- – rơi vào other	--- – rơi vào other
`auditor`	--- – rơi vào other	r-x – qua group `audit`	--- – rơi vào other
`guestlab`	--- – rơi vào other	--- – rơi vào other	--- – rơi vào other

Ma trận thao tác kỳ vọng suy ra từ bảng trên (✓ được phép, ✗ bị từ chối):

Tài khoản	Thư mục	Liệt kê / đọc	Tạo / sửa	Đổi tên / xóa	chmod / chown
`opsadmin`	app, logs, backup	✓	✓	✓	✓ chmod (owner); chown cần sudo
`deployer`	app	✓	✓	✓	chỉ chmod file do mình tạo
`deployer`	logs, backup	✗	✗	✗	✗
`auditor`	logs	✓	✗	✗	✗
`auditor`	app, backup	✗	✗	✗	✗
`guestlab`	app, logs, backup	✗	✗	✗	✗

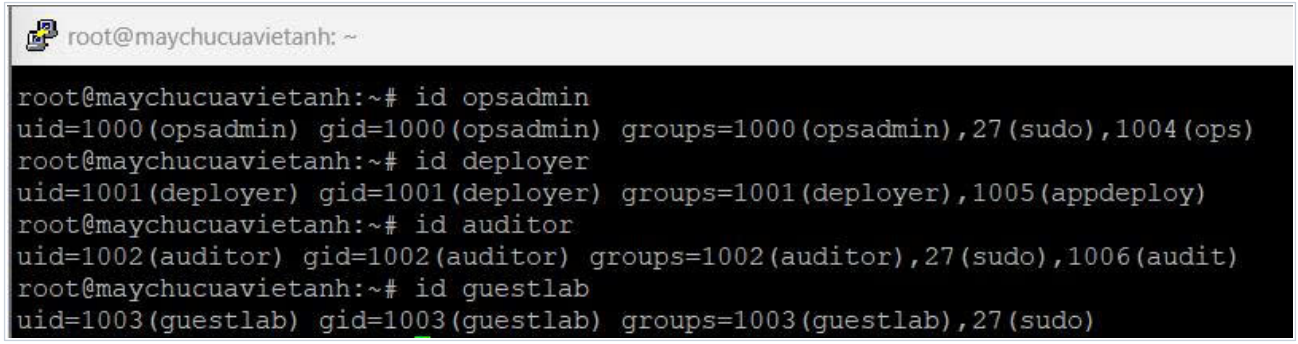
Lưu ý: auditor không đổi tên hay xóa được log vì thao tác đó cần quyền **w trên thư mục** `logs`, trong khi group chỉ có r-x. Auditor cũng không chmod/chown được vì chỉ owner (opsadmin) hoặc root mới đổi được permission và owner của file.

4. Các bước thực hiện

4.1. Tạo group vai trò và tài khoản

```
groupadd ops ; groupadd appdeploy ; groupadd audit
useradd -m opsadmin ; useradd -m deployer ; useradd -m auditor ; useradd -m guestlab
passwd <user>                          # đặt mật kh□u, không ghi lại trong h□ sơ
usermod -aG sudo,ops opsadmin
usermod -aG appdeploy deployer
usermod -aG audit auditor
```

`usermod -aG` thêm group phụ mà không xóa group cũ; nếu thiếu `-a`, user bị gỡ khỏi mọi group phụ khác, kể cả `sudo`. Quyền được gắn vào group chứ không gắn vào từng user, nên khi có thêm nhân sự triển khai chỉ cần `usermod -aG appdeploy <user>`, không phải sửa ACL. Tài khoản tạo bằng `useradd` không có `-s` sẽ dùng shell mặc định `/bin/sh` (dash), điều này thấy được qua thông báo lỗi dạng `-sh: 2: cd: ...` ở mục 5.

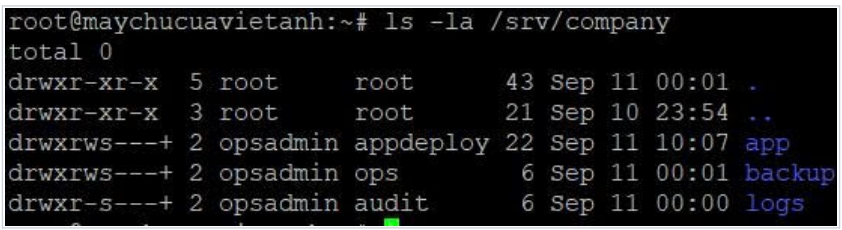


MC-01. Kết quả id của 4 tài khoản: group vai trò đúng thiết kế; auditor và guestlab còn thuộc sudo(27) – xem Sự cố S1

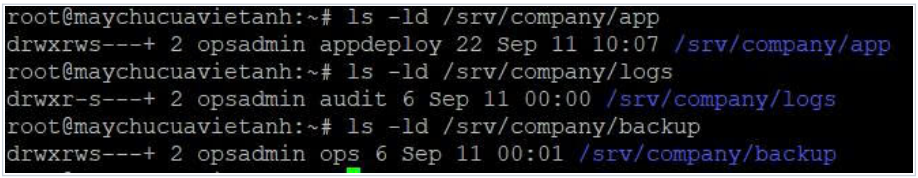
4.2. Cây thư mục, owner, permission và setgid

```
mkdir -p /srv/company/app /srv/company/logs /srv/company/backup
chown opsadmin:appdeploy /srv/company/app    ; chmod 2770 /srv/company/app
chown opsadmin:audit     /srv/company/logs   ; chmod 2750 /srv/company/logs
chown opsadmin:ops       /srv/company/backup ; chmod 2770 /srv/company/backup
```

Chữ số đầu tiên `2` là bit **setgid**. Trên thư mục, setgid khiến mọi file và thư mục con tạo bên trong nhận group của thư mục cha (ví dụ `appdeploy`) thay vì group chính của người tạo (`deployer`). Nhờ vậy file do một thành viên tạo vẫn thuộc group chung và các thành viên khác sửa được. Trong `ls -l`, setgid hiện thành chữ `s` ở vị trí x của group. Ba chữ số sau là quyền owner/group/other: `770` cho owner và group toàn quyền; `750` chỉ cho group đọc và đi vào thư mục; other luôn là `---`.



MC-02. ls -la /srv/company: owner, group, setgid (s) và dấu + báo hiệu ACL



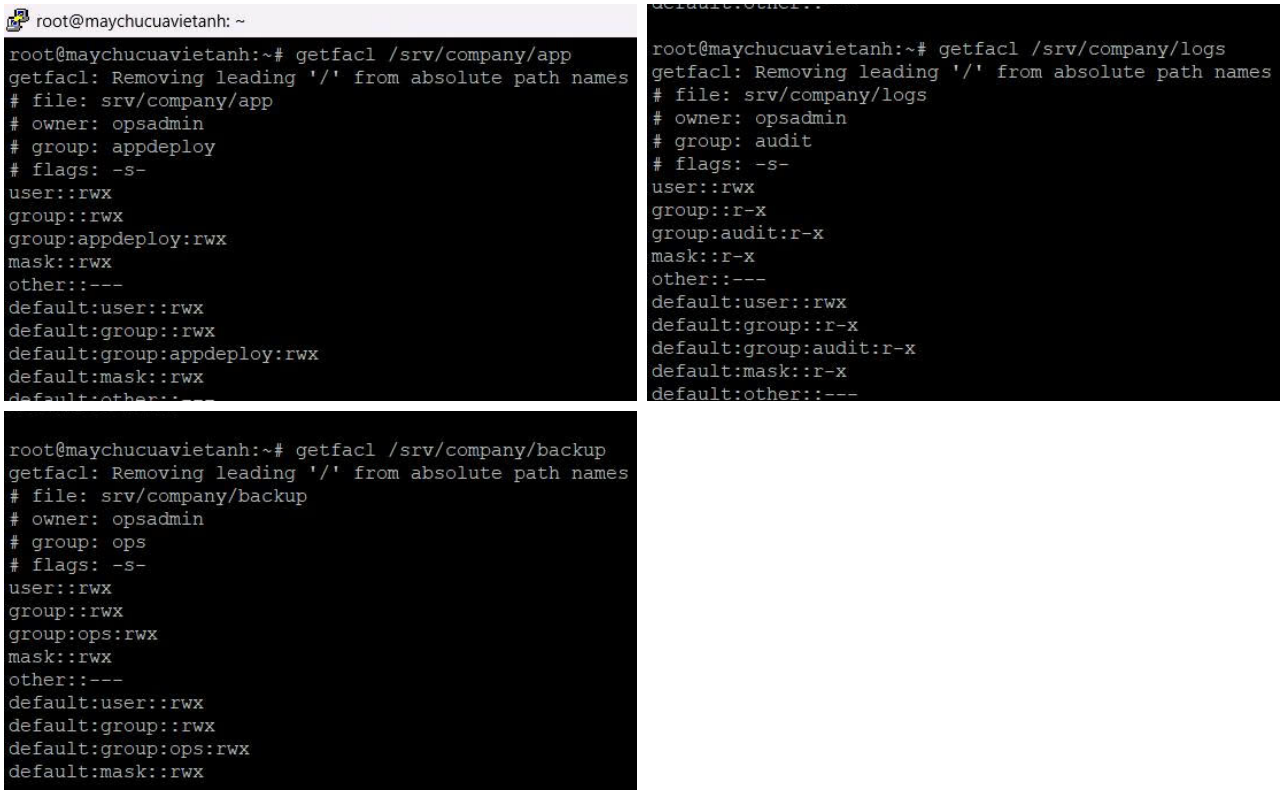
MC-03. ls -ld từng thư mục nghiệp vụ

4.3. ACL hiện hành và ACL mặc định

```
setfacl -m g:appdeploy:rwx /srv/company/app
setfacl -d -m u::rwx,g::rwx,g:appdeploy:rwx,o::--- /srv/company/app
setfacl -m g:audit:rx /srv/company/logs
setfacl -d -m u::rwx,g::rx,g:audit:rx,o::--- /srv/company/logs
setfacl -m g:ops:rwx /srv/company/backup
setfacl -d -m u::rwx,g::rwx,g:ops:rwx,o::--- /srv/company/backup
```

`-m` sửa ACL hiện hành của chính thư mục; `-d` đặt **ACL mặc định** để file/thư mục con mới tạo kế thừa. Setgid chỉ đảm bảo đúng group sở hữu, còn default ACL đảm bảo đúng bộ quyền. Khi thư mục có default ACL, kernel lấy quyền của file mới theo default ACL và **không áp dụng umask** của người tạo. Vì vậy file mới trong `app` vẫn cho group ghi dù người tạo đặt umask chặt.

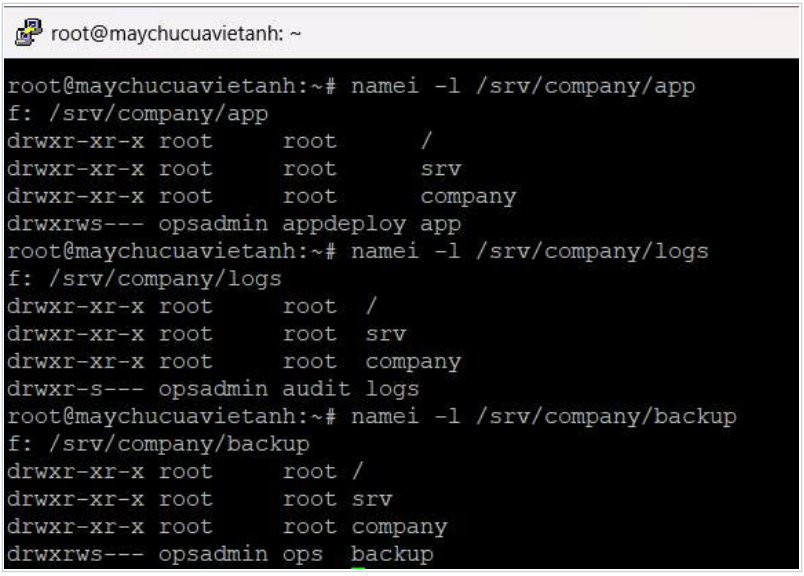
Dòng `mask::` là giới hạn trên cho mọi quyền của group và named entry. Ở `logs`, mask là `r-x` nên file log mới nhận quyền group tối đa `r--` (file thường không có x), và auditor không thể ghi. Bản ghi `group:appdeploy:rwx` trên `app` trùng với group sở hữu (`group::rwx`); việc giữ lại giúp chính sách tường minh khi getfacl và vẫn đúng nếu sau này đổi group sở hữu của thư mục.



MC-04. getfacl 3 thư mục: flags -s- (setgid), ACL hiện hành và default ACL (ảnh gốc cắt tại default:mask của backup; bản text ở 03_Cau_hinh/)

4.4. Kiểm tra quyền trên toàn bộ đường dẫn

Để vào được một thư mục, user cần quyền x trên **mọi** thành phần của đường dẫn. `namei -l` liệt kê từng cấp: `/`, `/srv`, `/srv/company` đều `drwxr-xr-x root root`, nên mọi user đều đi qua được ba cấp trên. Quyết định cho phép hay từ chối nằm hoàn toàn ở cấp cuối. `namei` không hiển thị ACL, vì vậy phải đọc kết hợp với MC-04.

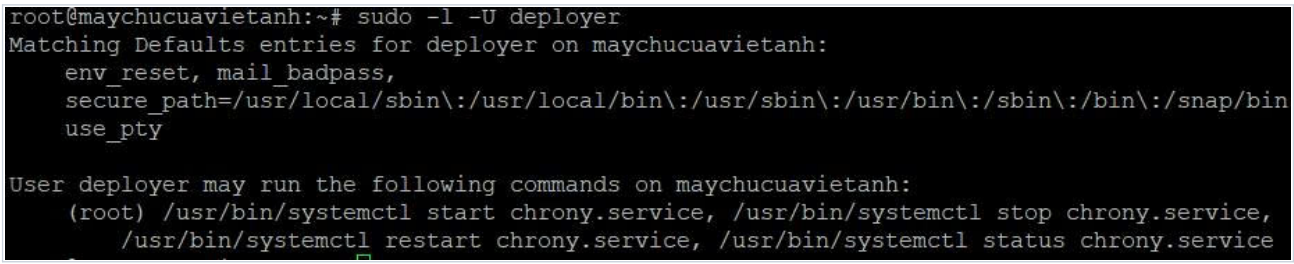


MC-05. namei -l cho 3 đường dẫn nghiệp vụ

4.5. Sudoers cho deployer

```
visudo -f /etc/sudoers.d/deployer
# Quy t□c có hiệu lực (đ□i chi□u sudo -l -U deployer):
deployer ALL=(root) /usr/bin/systemctl start chrony.service,   \
                    /usr/bin/systemctl stop chrony.service,    \
                    /usr/bin/systemctl restart chrony.service, \
                    /usr/bin/systemctl status chrony.service
```

`visudo` kiểm tra cú pháp trước khi ghi, tránh trường hợp một lỗi gõ làm hỏng toàn bộ sudo của server. Quy tắc cho deployer đúng 4 lệnh, viết bằng đường dẫn tuyệt đối để không bị đánh tráo bằng một file `systemctl` khác trong PATH. Tên service cũng được ghi cố định, nên `sudo systemctl restart ssh` sẽ bị từ chối. Quy tắc **không có NOPASSWD** (MC-06 không hiện nhãn NOPASSWD), không dùng `ALL=(ALL) ALL`, và deployer không thuộc group `sudo`. Defaults `use_pty` buộc lệnh sudo chạy trong pseudo-terminal riêng, ngăn tiến trình nền tiếp tục chạy sau khi phiên sudo kết thúc.



MC-06. sudo -l -U deployer: chỉ 4 lệnh systemctl cho chrony.service, chạy với quyền root

Hạn chế đã nhận diện: chrony điều khiển đồng hồ của toàn server, không gắn trực tiếp với việc triển khai nội dung. Nếu deployer dùng quyền `stop`, timestamp của mọi log có thể bị lệch, gây khó khăn cho chính việc kiểm toán. Đề xuất ở mục 7.3.

4.6. Group docker: phân tích rủi ro và quyết định

Thành viên group `docker` được gửi lệnh trực tiếp tới Docker daemon qua socket `/var/run/docker.sock`, mà daemon chạy bằng root. Người đó có thể chạy một container mount toàn bộ ổ đĩa của host, ví dụ `docker run -v /:/host -it ubuntu chroot /host`, và nhận ngay shell root trên host mà không cần mật khẩu. Hệ quả với mô hình phân quyền của bài:

- Vượt qua toàn bộ permission và ACL: đọc được `/srv/company/backup`, `/etc/shadow`, sửa hoặc xóa được log.
- Vượt qua sudoers: danh sách lệnh giới hạn ở mục 4.5 mất tác dụng.
- Mất khả năng truy vết: thao tác qua Docker không đi qua sudo nên không xuất hiện trong `journalctl _COMM=sudo`, trái với mục tiêu ban đầu của bài.

Quyết định: không thêm tài khoản nào vào group docker. MC-01 xác nhận không tài khoản nào trong 4 tài khoản thuộc group này. Khi cần vận hành Docker (Bài 5), opsadmin dùng `sudo docker ...` để mỗi lệnh đều được ghi log. Nếu deployer cần khởi động lại landing page, sudoers chỉ nên cấp lệnh cố định kèm tên container, ví dụ `/usr/bin/docker restart landing-public`. Không cấp `/usr/bin/docker *`, vì tham số tự do vẫn tương đương quyền root. Giải pháp thay thế là Docker rootless.

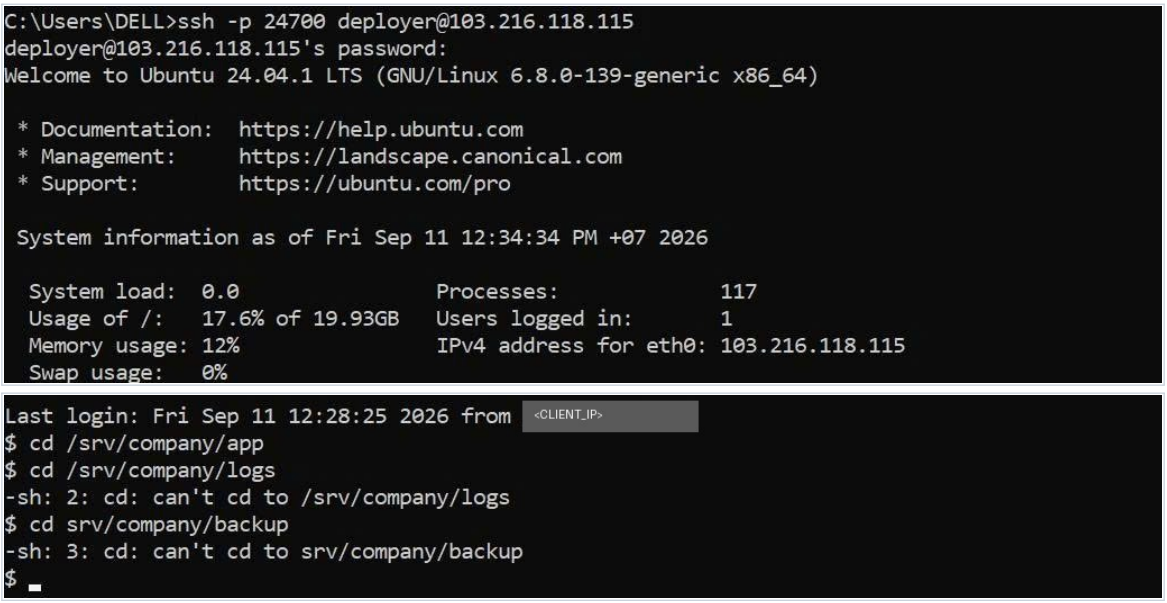
5. Kết quả kiểm thử

Mỗi tài khoản đăng nhập SSH riêng và thử vào 3 thư mục nghiệp vụ. Bản chép text của từng phiên nằm trong `04_Log/`.

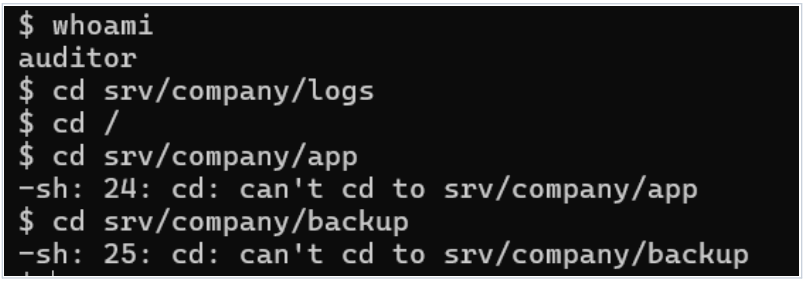
5.1. Biên bản kiểm thử theo tài khoản

#	Tài khoản	Lệnh	Kỳ vọng	Thực tế	Đánh giá	MC
T1	deployer	`cd /srv/company/app`	Được phép	Thành công	**Đạt**	07
T2	deployer	`cd /srv/company/logs`	Từ chối	`can't cd`	**Đạt**	07
T3	deployer	`cd srv/company/backup` (đứng ở home)	Từ chối	`can't cd`	**Không hợp lệ (S2)**	07
T4	auditor	`cd srv/company/logs`	Được phép	Thành công	**Đạt***	08
T5	auditor	`cd /` rồi `cd srv/company/app`	Từ chối	`can't cd`	**Đạt**	08
T6	auditor	`cd srv/company/backup`	Từ chối	`can't cd`	**Đạt**	08
T7	guestlab	`cd /` rồi `cd srv/company/app`	Từ chối	`can't cd`	**Đạt**	09
T8	guestlab	`cd srv/company/logs`	Từ chối	`can't cd`	**Đạt**	09
T9	guestlab	`cd srv/company/backup`	Từ chối	`can't cd`	**Đạt**	09

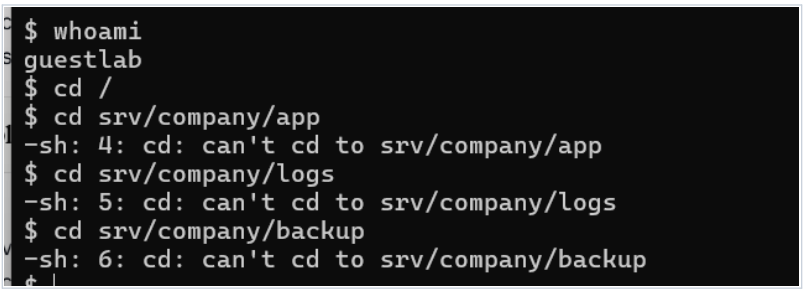
* T4: thư mục hiện hành trước lệnh không hiển thị trong ảnh. Đường dẫn tương đối `srv/company/logs` chỉ tồn tại khi đang đứng ở `/`; các lệnh T5, T6 chạy sau `cd /` nên chắc chắn trỏ đúng `/srv/company/...`.



MC-07. deployer đăng nhập SSH (12:34, 11/09/2026) và thử 3 thư mục; ảnh cắt bỏ phần MOTD, IP máy khách đã che (ảnh đầy đủ ở 05_Minh_chung/)



MC-08. auditor: vào được logs, bị từ chối ở app và backup



MC-09. guestlab: bị từ chối ở cả 3 thư mục

5.2. Diễn giải kết quả

Lệnh `cd` cần quyền x (search) trên thư mục. Kernel đánh giá ACL theo thứ tự: nếu là owner thì dùng `user::`; nếu không, xét named user; tiếp theo là group sở hữu và các named group mà user là thành viên (giới hạn bởi mask); không khớp mục nào thì dùng `other::`. Áp vào kết quả kiểm thử:

- T1: deployer thuộc `appdeploy`, khớp `group:appdeploy:rwx` (mask rwx), có x nên vào được.
- T4: auditor thuộc `audit`, khớp `group:audit:r-x` (mask r-x), có x nên vào được, nhưng không có w nên không tạo, xóa hay đổi tên được gì trong thư mục.
- T2, T5, T6: user không phải owner và không thuộc group được cấp, rơi xuống `other::---`, nên bị từ chối.
- T7–T9: guestlab không thuộc group nghiệp vụ nào nên rơi vào `other::---` ở cả 3 thư mục, đúng yêu cầu 6 của đề.

5.3. Giới hạn của bộ kiểm thử hiện có

Shell `/bin/sh` (dash) chỉ báo `can't cd to ...` mà không nêu lý do. Vì vậy thông báo này không phân biệt được "không đủ quyền" với "không tồn tại"; đây chính là nguyên nhân T3 không hợp lệ. Bộ kiểm thử hiện mới dừng ở quyền đi vào thư mục. Các thao tác ghi, sửa, đổi tên, xóa, chmod, chown chưa được thực hiện, và `logs`, `backup` đang rỗng nên chưa có file để thử. Các hạng mục này được liệt kê ở mục 7.2.

6. Sự cố phát sinh, khoanh vùng và khắc phục

S1 – auditor và guestlab thuộc group sudo	**Mức: Cao**
Phát hiện	Đối chiếu `id` với thiết kế (MC-01): `auditor ... groups=...,27(sudo),1006(audit)` và `guestlab ... groups=...,27(sudo)`.
Tác động	Ubuntu cấp `%sudo ALL=(ALL:ALL) ALL` cho group sudo, nên hai tài khoản này có toàn quyền root. guestlab có thể `sudo cat /srv/company/backup/...`; auditor có thể `sudo rm` hoặc sửa log. Mọi ACL ở mục 4 bị vô hiệu, vi phạm yêu cầu không cấp sudo toàn phần. Kiểm thử T4–T9 chỉ chứng minh quyền ở mức thư mục khi không dùng sudo.
Khoanh vùng	Chỉ opsadmin cần sudo toàn quyền; deployer đúng thiết kế (không thuộc sudo). Thời điểm và lệnh đã thêm hai tài khoản vào sudo cần đối chiếu trong `/var/log/auth.log`.
Khắc phục	`gpasswd -d auditor sudo` ; `gpasswd -d guestlab sudo`, sau đó hai tài khoản đăng xuất và đăng nhập lại để nhận group mới.
Kiểm chứng	`id auditor ; id guestlab` không còn 27(sudo); `sudo -l -U auditor` và `sudo -l -U guestlab` báo "is not allowed to run sudo".
Trạng thái	**Chưa có minh chứng khắc phục**

S2 – Kiểm thử bằng đường dẫn tương đối cho kết quả không hợp lệ	**Mức: Trung bình**
Phát hiện	Ở phiên deployer (MC-07), lệnh `cd srv/company/backup` chạy từ thư mục home, nên thực chất trỏ tới `/home/deployer/srv/company/backup` (không tồn tại).
Khoanh vùng	dash không in lý do lỗi, nên "can't cd" không phân biệt được thiếu quyền với sai đường dẫn.
Khắc phục	Các phiên sau (auditor, guestlab) chạy `cd /` trước khi dùng đường dẫn tương đối (MC-08, MC-09). Với deployer cần chạy lại bằng đường dẫn tuyệt đối `cd /srv/company/backup` hoặc `ls /srv/company/backup`; `ls` in rõ "Permission denied".
Trạng thái	**Đã khắc phục cách kiểm thử; T3 chưa được chạy lại**

S3 – Cấu hình và thu minh chứng bằng phiên root	**Mức: Trung bình**
Phát hiện	Các ảnh MC-01 đến MC-06 có dấu nhắc `root@maychucuavietanh`.
Tác động	Trái quy định 5 của đề. Thao tác bằng root không đi qua sudo nên không để lại dấu vết theo từng người trong `journalctl _COMM=sudo`.
Khắc phục	Thực hiện quản trị bằng `opsadmin` kèm `sudo`; thu lại minh chứng cấu hình từ phiên opsadmin.
Trạng thái	**Chưa có minh chứng khắc phục**

7. Kết luận, rủi ro còn lại và đề xuất

7.1. Kết luận

Cấu trúc phân quyền đã được triển khai đúng thiết kế ở mức thư mục. Ba group vai trò được tạo, mỗi thư mục có owner, group, setgid và default ACL phù hợp, other bị đóng hoàn toàn. Kiểm thử cho thấy deployer vào được app nhưng bị từ chối ở logs; auditor chỉ vào được logs; guestlab bị từ chối ở cả 3 thư mục. Sudoers của deployer đúng nguyên tắc: danh sách lệnh cố định, không NOPASSWD, không ALL.

Tuy nhiên, hệ thống **chưa đạt nguyên tắc đặc quyền tối thiểu**, vì auditor và guestlab vẫn thuộc group sudo (S1). Chừng nào S1 chưa được khắc phục, các kiểm soát truy cập ở mục 4 chỉ có hiệu lực với người dùng không chủ động gõ `sudo`.

7.2. Hạng mục chưa hoàn tất

- Khắc phục S1 và thu minh chứng `id`, `sudo -l -U` sau khắc phục (checklist 03, 21, 23).
- Tạo file mẫu trong `logs` và `backup`; kiểm thử đầy đủ đọc, ghi, đổi tên, xóa, chmod, chown bằng từng tài khoản; chạy lại T3 bằng đường dẫn tuyệt đối (16, 17, 20, 24, 25).
- Tạo file và thư mục mới bằng deployer, chứng minh kế thừa group và ACL bằng `ls -l`, `getfacl` (13).
- Chạy một lệnh sudo trong danh sách và một lệnh ngoài danh sách; thu `journalctl _COMM=sudo`, nội dung file sudoers và `visudo -c` (27–30).
- Cấu hình umask (đề xuất `027` trong `~/.profile` của tài khoản vận hành) và kiểm tra file mới trong home (31).
- Trích xuất log thay đổi user/group từ `/var/log/auth.log` (05).

7.3. Rủi ro còn lại và đề xuất cải tiến

#	Mức	Rủi ro	Đề xuất
1	**Cao**	auditor, guestlab có sudo toàn quyền (S1).	Gỡ khỏi sudo; định kỳ rà soát bằng `getent group sudo`.
2	**Cao**	Chưa kiểm thử thao tác ghi/xóa/đổi tên/chmod; logs và backup rỗng.	Hoàn tất bộ kiểm thử ở mục 7.2 trước khi nghiệm thu.
3	**Trung bình**	Sudoers cho deployer quản lý chrony: không gắn với nghiệp vụ triển khai; quyền `stop` làm lệch thời gian hệ thống và timestamp log.	Bỏ `stop`; khi có Bài 5, thay bằng lệnh cố định cho container landing page. Xác nhận chrony đã được cài (Ubuntu 24.04 mặc định dùng systemd-timesyncd).
4	**Trung bình**	Chỉ owner opsadmin ghi được vào logs; khi có dịch vụ thật ghi log, sẽ phát sinh nhu cầu nới quyền tùy tiện.	Tạo user dịch vụ riêng và cấp ACL `u:<svc>:rwx` có kiểm soát, không nới quyền cho group audit.
5	**Trung bình**	Cấu hình bằng root (S3), không truy vết được người thao tác.	Quản trị qua opsadmin + sudo; cân nhắc khóa đăng nhập SSH trực tiếp bằng root.
6	Thấp	Thư mục app không có sticky bit: thành viên appdeploy xóa được file của nhau.	Chấp nhận trong một nhóm triển khai; nếu nhóm lớn, cân nhắc `chmod +t` hoặc quy trình deploy.
7	Thấp	Tài khoản dùng shell `/bin/sh`; guestlab không có nhu cầu shell tương tác lâu dài.	Đặt `/bin/bash` cho tài khoản vận hành; khóa hoặc đặt ngày hết hạn cho guestlab (`usermod -e`) sau khi kiểm tra xong.

Phụ lục – Danh mục minh chứng

Mã	File trong 05_Minh_chung/	Nội dung
MC-01	MC-01_id_4_tai_khoan.jpg	id của 4 tài khoản
MC-02	MC-02_ls_la_srv_company.jpg	ls -la /srv/company
MC-03	MC-03_ls_ld_tung_thu_muc.jpg	ls -ld từng thư mục
MC-04	MC-04_getfacl_3_thu_muc.jpg	getfacl app, logs, backup
MC-05	MC-05_namei_duong_dan.jpg	namei -l 3 đường dẫn
MC-06	MC-06_sudo_l_deployer.jpg	sudo -l -U deployer
MC-07	MC-07_deployer_ssh_cd.jpg	Phiên kiểm thử deployer (đã che IP máy khách)
MC-08	MC-08_auditor_cd.png	Phiên kiểm thử auditor
MC-09	MC-09_guestlab_cd.png	Phiên kiểm thử guestlab